



HANDVANTAGE

A REFERENCE FOR PROCUREMENT COMMITTEES

The Agentic AI Procurement *Handbook.*

Sector dossiers, persona briefs, and the architectural reference for buying and deploying agentic AI in regulated enterprises.

A peer-to-peer reference, not a sales document.

This handbook compiles the editorial published at **workspace.handvantage.com/insights** into a single reference for procurement committees evaluating agentic AI for deployment in regulated environments. It is written for senior buyers — CISOs, CFOs, COOs, compliance officers, and the founders and boards they brief.

The content is human-authored under the founder's byline. Every regulatory citation references published guidance — by article number, by clause number, by document number — so a reader who wants to verify any claim has the path to do so.

The handbook is published openly. No email gate. No registration. Reference it, share it, attach it to your committee deck, cite it in your own writing. The credit and the link back to the source are appreciated; the use is not restricted.

PUBLISHED: 2026-05-10

VERSION: 1.0

AUTHOR: JOSH OLAYEMI, FOUNDER, HANDVANTAGE

CONTACT: HELLO@HANDVANTAGE.COM

CANONICAL URL: [WORKSPACE.HANDVANTAGE.COM](https://workspace.handvantage.com)

LICENCE: FREE TO SHARE, CITE, AND FORWARD

Table of *contents*.

PART I

The procurement landscape

01	Why agentic AI procurement keeps stalling	1
02	The five-voice procurement negotiation	—

PART II

For specific roles

03	For the CISO	—
04	For the CFO	—
05	For the CEO and the board	—

PART III

Sector dossiers

06	Financial services — FINRA, SEC, the audit-trail problem	—
07	Healthcare — HIPAA, FDA SaMD, the supervision question	—
08	Fintech — BSA/AML, fair lending, the sponsor-bank question	—
09	Canadian public sector — TBS Directive, sovereignty, Indigenous data	—
10	Legal services — privilege, competence, the supervision rule	—

PART IV

Architecture and posture

11	The 7-Layer Defence Architecture	—
12	Continuous compliance — what the phrase actually means	—

PART I

CHAPTER 01

Why agentic AI procurement *keeps stalling.*

Roughly 40% of agentic AI projects are being cancelled or shelved, often after substantial investment. The pattern in cancelled projects is consistent — and it isn't about technology fit.

Gartner's research recently put a number on something we'd been seeing in the field: roughly 40% of agentic AI projects are being cancelled or shelved, often after substantial investment. The headline reaction is to point at technology immaturity. The actual pattern, when we look at the cancelled projects we have visibility into, is consistently about governance — not about whether the technology works, but about whether the organisation can defend its use of the technology.

Cancelled projects fall into three rough categories. The first is the technology-fit cancellation: the platform did not deliver what was promised on the demo. These are real, but rarer than the headline suggests. The second is the cost-fit cancellation: the platform delivered, but the unit economics didn't work at production scale. The third — and most common in our sample — is the governance-fit cancellation: the platform delivered, the costs penciled, but the security or compliance team could not approve a production rollout because the evidence story didn't exist.

The governance-fit cancellation has a recurring shape. The technology team builds a proof of concept, demonstrates value, and submits a production-rollout proposal. The compliance team reviews the proposal and asks for evidence — not for whether the platform can do prompt-injection defence in a demo, but for whether the platform produces contemporaneous, machine-verifiable, framework-mapped evidence of every action it takes. The technology team turns to the vendor. The vendor says some version of "we generate logs, you can build a compliance pipeline on top." The compliance team responds: "we don't have the budget, the people, or the time to build a compliance pipeline; the platform should produce the evidence directly." The proposal stalls. After two or three revisions, the proposal is shelved.

The shape is consistent enough that we treat it as the default failure mode for any agentic AI project where the buying organisation is in a regulated sector. The pattern is not a technology problem. The platforms work. The pattern is a structural mismatch between what vendors are selling (a product layer) and what regulated buyers need (a product layer plus an evidence layer plus a control-mapping layer plus a verification layer).

The governance answer is to build the evidence layer into the platform from the architectural premise, not as an add-on. This is what the 7-Layer Defence Architecture is — every layer produces audit events, every event is signed, every event is mapped to specific framework controls, every assessment is run against the runtime evidence rather than against an attestation document. The architecture is structural; the evidence is contemporaneous; the assessment is continuous.

This shape doesn't make the project's compliance review trivial. It makes the review possible. The conversation between the technology team and the compliance team becomes "here is the Trust Report scoped to your frameworks, with your audit window" rather than "we'll figure out how to prove this once we're in production." The proposal moves forward. The project ships. The 40% failure rate moves the other way.

We are not arguing that this is the only design pattern that works. We are arguing it is the design pattern that addresses the actual failure mode in cancelled agentic AI projects. The vendors who continue to ship a product layer alone will continue to lose deals to vendors who ship the evidence layer alongside it. The buyers who continue to evaluate platforms on demo behaviour alone will continue to cancel projects when the compliance review reaches the evidence question. The pattern is settled enough now that we expect it to continue.